11. セキュリティ設計

11.1 AWSサービスにおけるセキュリティ対策

下記のAWSサービスを利用し、セキュリティ対策を行う。

IAM

本システムで使用するユーザーを下記に示す。

No	ユーザー	グループ	説明
1	特権(root)ユーザー	-	・通常運用時には使用しない。
2	個人ユーザー	IAMグループで管理	・KDDI様の担当者様ごとに個別に発行するユーザー。
3	SMTP認証用ユーザー	-	・SESを利用してメールを送信する際に使用する、SMTP認証専用のユーザー。 ・AWS マネジメントコンソールでのログインは許可しない ・パスワードはAWSにより自動で払い出されたものを使用する。
4	運用(構築)ユーザー	-	・アイレット利用ユーザー。 ・アイレットメンバーは弊社内部の SAML 認証(adminpack) を介してAWS アカウントにログインを行うため、個別にIAMユーザーは作成しない。 ・AWS マネジメントコンソールにログインする際は、ReadOnly 権限と Admin 権限の2種類あり、 Admin 権限でのログイン時は理由 (運用作業に対応するBacklog課題番号)の記入が必須となる。 （どちらの権限であってもログインの履歴がアイレット社内に記録される。）

本システムでは、以下の方針で IAM ユーザーを運用する。

- 許可された利用者に対し必要最小限の権限を付与する IAM ユーザーを発行する。
- 利用者間で IAM ユーザーは共有せず、個別に IAM ユーザーを作成し、使用する。
- ID/パスワードによる認証に加え、多要素認証(MFA)を有効化する。
- IAM ユーザー作成時はランダムなパスワードを生成し、初回ログイン後にパスワード変更を行う。
- IAM グループを作成し、それぞれの役割に応じた適切な権限を割り当て、制御を行う。
  - 本システムで取り扱う IAM ユーザーについては、それぞれの役割に応じた IAM グループに配置する。
    - 具体的な権限については詳細設計に記載する。
- IAMユーザーの定期的な棚卸しは、KDDI様側で実施する。
- IAMユーザーのパスワードポリシーは以下の方針とする。
  - パスワードの最小文字数：12
  - 少なくとも 1 つのアルファベットの大文字 (A～Z) を使用すること。
  - 少なくとも 1 つのアルファベットの小文字 (a～z) を使用すること。
  - 少なくとも 1 つの数字を使用すること。
  - 少なくとも 1 つの英数字以外の文字を使用すること。(! @ # $ % ^ & * ( ) _ + - = [ ] {} | ')
  - パスワードの有効期間をオンにする。
    - パスワードの有効期間は90日とする。

- パスワードの再利用を禁止する。
  - 過去12世代以内のパスワードの再設定は不可とする。

Amazon GuardDuty

- マネージド型脅威検出サービスである GuardDuty を利用して、本システムに対する偵察行為やAWS アカウントの侵害、S3 のアクセス検知や不正利用等を検知する。
- VPC フローログ（ネットワークトラフィックログ）、CloudTrail イベント（AWS アカウント内のアクティビティ、イベント関連ログ）を分析し、脅威を検知する。
  - GuardDuty で検知した際、セキュリティリスクの高さによって High、Medium、Low の重要度に分類される。
    - High、Medium に分類されるセキュリティリスクについては、検知後に運用担当者に通知を行い、状況の確認、及び対応を行う。

AWS Config

- AWS リソースの設定値を AWS Config に収集する。AWS Config は準拠すべきルールを事前に設定し、その内容に沿った構成変更が行われているかを評価する。
- すべての AWS アカウント／リージョン／リソースタイプについて AWS Config を有効にする。
  - 通常利用していないリージョンについても AWS Config を有効にし、設定ミス（人為的なミス）があった場合も検出を行う。「すべてのリソースを記録」することで、新しく追加されたリソースタイプについても自動的に記録対象とする。

AWS Trusted Advisor

- AWSの利用状況を分析し、情報セキュリティの推奨事項を取得し、各種AWSリソースの設定項目の改善を行う。

AWS Shield Standard

- ネットワーク層（Layer3〜4）への DDoS 攻撃対策は、AWS Shield Standard により実現する。
- AWS Shield Standard は、DirectConnect 経由のネットワークを含め、AWS 外のネットワークに面した AWS サービスのネットワークに透過的に適用され、DDoS 攻撃の緩和は自動的に実施される。

CloudTrail

- AWSリソースにおけるAPIコールのキャプチャを行うことで、不正な操作、不正なアクセスによるリソース変更の追跡を可能とする。
- CloudTrail証跡設定にて、ログファイルの整合性の検証機能を有効化し、ログの改ざんを検知する。
- CloudTrailログの保管期間については、10.ログ管理設計　に記載する。

11.2 データ暗号化

- S3バケットに保存される全てのログデータは、サーバーサイド暗号化(SSE-S3)を有効にし、暗号化して保管する。
- 別途暗号化が必要なAWSサービスについては、AWS KMSを利用し、暗号鍵の作成と管理を行う。
  - カスタマーマネージドキーを作成し、暗号化を行う。
  - カスタマーマネージドキーは自動ローテーションを設定する。

11.3 認証情報管理

- SMTP認証情報はオンプレミス側で保持する。
  - SMTP認証情報は、オンプレミス側で共通のものを使用するため、アカウントロック機能は実装しない。
  - SMTP認証情報はAWSアカウントごと、リージョンごとに異なるため、本番の東京リージョンと大阪リージョン、検証の東京リージョンの計3セット準備する。
  - SMTP認証情報はiretが発行し、boxにてKDDI様への受け渡しを行う。
  - 現状はSMTP認証情報の定期ローテーションは実施しない方針とする。ただし、社内セキュリティポリシーが変更した際は、内容に準じて対応する。

11.4 ネットワークセキュリティ

- 本システムではインターネットよりアクセスされるリソースを配置しないため、プライベートサブネットのみの構成とする。
- セキュリティグループを利用し、リソースレベルでの通信制御を実施する。
  - SESのVPCエンドポイントにアタッチするセキュリティグループを設定する。
    - 許可された通信（オンプレミス環境からのTCP/587,25番ポート且つ特定のIPアドレス）からのみSESエンドポイントへのアクセスを許可し、意図しないアクセスを遮断することで通信経路を最小化する。
- 本システムの通信制御は、直接アタッチするセキュリティグループで厳密に行うため、ネットワークACLによる追加の制限は行わないこととする。
- S3バケットポリシーにて許可された対象以外からのオブジェクトアクセスを拒否する。
- SMTPインターフェースを介したSESでのメール送信はSMTP/TLS1.2以上による暗号化が必須となる。
  - 上記仕様のため、メール送信元はSMTP/TLS1.2以上を指定し、送信を行うこと。